

1. Denial of Service (DoS)

What is DoS?

- Denial of Service (DoS) is a cyberattack aimed at making a machine, network, or service unavailable to its intended users.
- It typically floods the target with excessive requests, overwhelming its capacity and causing slowdowns or complete shutdown.

Types of DoS attacks:

- Volume-based attacks: Saturate bandwidth with high traffic (e.g., UDP floods, ICMP floods).
- Protocol attacks: Exploit weaknesses in protocols (e.g., SYN flood, Ping of Death).
- Application layer attacks: Target specific applications/services (e.g., HTTP floods).

Distributed Denial of Service (DDoS):

- A more powerful form involving multiple compromised systems (botnets) attacking a single target.
- Harder to mitigate due to

You said:

sion 3: 🔖 Web Application Security Risks 🔖 Identifying the Application Security Risks 🔖 Threat Risk Modelling 🔖 Other HTTP fields 🔖 Overview of Burp Suite features

ChatGPT said:

Got it! Here's a detailed theory overview for **Session 3** topics:

Session 3: Web Application Security Risks & Tools

1. Web Application Security Risks

What are Web Application Security Risks?

- Vulnerabilities or weaknesses in a web application that can be exploited by attackers to compromise confidentiality, integrity, or availability.
- Web apps face unique risks due to their exposure on the internet and complex input/output interactions.

Common Web Application Risks (Based on OWASP Top 10)

- Injection flaws (SQL, NoSQL, OS command injection)
- Broken Authentication
- Sensitive Data Exposure
- XML External Entities (XXE)

- Broken Access Control
- Security Misconfiguration
- Cross-Site Scripting (XSS)
- Insecure Deserialization
- Using Components with Known Vulnerabilities
- Insufficient Logging & Monitoring

Why it matters

- Web apps are prime targets due to their accessibility.
- Successful attacks can lead to data theft, data loss, service disruption, or unauthorized control.

2. Identifying Application Security Risks

Techniques for Risk Identification

- Code Review: Manual or automated inspection of source code for vulnerabilities.
-

Static Application Security Testing (SAST): Automated tools analyze source code without executing it.

-
- Dynamic Application Security Testing (DAST):** Testing running applications to find runtime vulnerabilities.
-
- Penetration Testing:** Simulated attacks to identify exploitable security flaws.
-
- Threat Modeling:** Systematic approach to identify, quantify, and address security risks during design.

Common Indicators

- Unexpected application behavior
- Unusual logs or errors
- Inputs accepted without validation
- Unprotected sensitive data flows

3. Threat Risk Modelling

What is Threat Modeling?

- Process of identifying threats, vulnerabilities, and risks in an application or system.
-

Helps prioritize mitigation efforts based on impact and likelihood.

Steps in Threat Modeling

1.
Identify assets: What needs protection? (data, users, systems)
 2.
Create an architecture overview: Map data flows, trust boundaries, and components.
 3.
Identify threats: Use frameworks like STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege).
 4.
Assess risks: Estimate impact and likelihood.
 5.
Define mitigation strategies: Controls, design changes, or monitoring.
-

4. Other HTTP Fields

Understanding HTTP Request and Response Headers

- HTTP headers carry additional info between client and server, influencing security.

Important Headers Related to Security

- **Content-Security-Policy (CSP):** Controls which resources can be loaded, mitigating XSS.
- **Strict-Transport-Security (HSTS):** Forces HTTPS connections, preventing downgrade attacks.

- **X-Frame-Options:** Prevents clickjacking by restricting framing.
 - **X-Content-Type-Options:** Stops MIME sniffing, reducing risk of XSS.
 - **Set-Cookie:** Controls cookies attributes like HttpOnly and Secure for better session security.
 - **Cache-Control:** Manages caching, important to avoid sensitive data leaks.
-

5. Overview of Burp Suite Features

What is Burp Suite?

- A popular integrated platform for web application security testing.
- Used mainly by penetration testers to identify and exploit web vulnerabilities.

Key Features

- **Proxy:** Intercepts and modifies HTTP(S) traffic between browser and server.
- **Spider:** Crawls the application to map its structure and discover pages.
- **Scanner:** Automated vulnerability scanner to detect common issues (available in Pro version).
-

Intruder: Automates customized attacks like brute forcing or fuzzing inputs.

-

Repeater: Manually modify and resend individual requests for testing.

-

Sequencer: Analyzes randomness of session tokens.

-

Decoder: Encodes/decodes data in multiple formats.

-

Comparer: Diff tool for comparing requests, responses, or other data.

Why Use Burp Suite?

-

Central tool for manual and automated web security testing.

-

Helps testers understand application logic, test inputs, and find security flaws.